

PENETRATION TEST REPORT

Report Information

- Client: TryHackMe (training)
- Assessment Type: External Penetration Test
- Target: 10.113.174.136
- Assessment Date: 16/06/2026
- Tester: Titanium00
- Classification: Confidential

1. Executive Summary

Overview

A penetration test was conducted against the target system to identify security vulnerabilities that could be exploited by an attacker.

During the assessment, multiple security weaknesses were identified, leading to unauthorized access to the target system.

Key Findings

Finding	Severity
Information disclosure via web directory (hash files)	Medium
Weak password (MD5 hash cracked)	High
Docker group misconfiguration leading to privilege escalation	Critical

Overall Risk Rating

High : Overall risk is rated High due to successful credential compromise and privilege escalation resulting in complete host compromise.

Business Impact

Successful exploitation of the identified vulnerabilities could allow an attacker to:

- Gain unauthorized access to sensitive information.
- Access internal resources.
- Execute arbitrary commands.
- Compromise system confidentiality, integrity, and availability.

2. Scope of Assessment

Target Information

Item	Value
Target Name	UltraTech
IP Address	10.113.174.136
Operating System	Linux (Ubuntu)
Assessment Type	Black Box

In-Scope Services

Service	Port
SSH	22
HTTP (port 80)	80
HTTP (port 31331)	31331

3. Methodology

The assessment followed a structured penetration testing methodology consisting of:

3.1 Reconnaissance

- Nmap scan to discover open ports and running services.
- Identified ports: 22 (SSH), 80 (HTTP), 31331 (HTTP).

3.2 Enumeration

- Gobuster directory enumeration on the web server (port 31331).
- Discovered directories: `/admin`, `/uploads`.

3.3 Vulnerability Analysis

- Discovered hash files containing MD5 hashes.
- Weak password policy allowed easy cracking of hashes.

3.4 Exploitation

- Cracked hashes using Hashcat (mode 0 – MD5).
- Used cracked credentials to access the machine via SSH as user `r00t`.

3.5 Post-Exploitation

- Identified that user `r00t` was part of the `docker` group.
- Exploited Docker misconfiguration to mount the host filesystem and escalate privileges to `root`.
- Retrieved the root SSH private key.

4. Attack Narrative

The following attack path was used to compromise the target:

1. Initial reconnaissance with Nmap identified multiple exposed services, including SSH (port 22) and two HTTP services (ports 80 and 31331).
2. Web enumeration (Gobuster) on port 31331 revealed directories `/admin` and `/uploads`.
3. Directory exploration uncovered hash files containing MD5 hashes for users `r00t` and `admin`.
4. The hashes were cracked using Hashcat (mode 0 – MD5) with the `rockyou.txt` wordlist, revealing plaintext passwords.
5. The cracked credentials were used to log in via SSH as the user `r00t`.
6. Post-exploitation enumeration (`id`) revealed that `r00t` was a member of the `docker` group.
7. The Docker misconfiguration was exploited using `GTF0Bins` technique to mount the host filesystem and escalate privileges to `root`.
8. Root access allowed retrieval of the root SSH private key from `/root/.ssh/id_rsa`.

5. Detailed Findings

Finding 1 – Information Disclosure via Web Directory

Severity: Medium

Reason for Severity:

This vulnerability exposes sensitive data (password hashes) but does not directly allow system access. However, it serves as a stepping stone for further attacks (hash cracking).

Description:

The web server (port 31331) exposed a directory containing sensitive files, including MD5 hashes of user credentials.

Impact:

An attacker can retrieve the hashes and attempt to crack them offline, leading to credential compromise.

Evidence:

- Directory `/uploads` found via Gobuster.
- Files contained hashes: `f357a0c52799563c7c7b76c1e7543a32` (user `r00t`) and `0d0ea5111e3c1def594c1684e3b9be84` (user `admin`).

Affected Assets:

- Web server (port 31331)
- Directory `/uploads`

Remediation:

- Restrict access to sensitive directories.
- Do not store password hashes in publicly accessible locations.
- Implement proper access controls (e.g., `.htaccess`).

Finding 2 – Weak Password Policy (MD5 Hashes)

Severity: High

Reason for Severity:

Cracked passwords allowed direct login to the system via SSH, granting unauthorized access to a low-privileged user account. This is a high risk because it enables lateral movement and further exploitation.

Description:

The password hashes discovered were MD5 (mode 0), which are susceptible to dictionary attacks. Weak passwords were cracked within seconds using `rockyou.txt`.

Impact:

An attacker can obtain plaintext passwords and gain unauthorized access to the system.

Evidence:

- Hashcat successfully cracked both hashes:
- `f357a0c52799563c7c7b76c1e7543a32` → `<password>`
- `0d0ea5111e3c1def594c1684e3b9be84` → `<password>`

Affected Assets:

- User accounts (`r00t`, `admin`)

Remediation:

- Enforce strong password policies (minimum length, complexity).
- Use modern hashing algorithms (bcrypt, Argon2) instead of MD5.
- Implement account lockout policies to prevent brute-force attacks.

Finding 3 – Docker Group Misconfiguration (Privilege Escalation)

Severity: Critical

Reason for Severity:

This vulnerability allows a low-privileged user (who is a member of the `docker` group) to escape the container and mount the host filesystem, gaining full root access to the host machine. This is the highest risk because it results in complete system compromise.

Description:

The user `r00t` was found to be a member of the `docker` group, allowing them to run containers with host-level access.

Impact:

An attacker can escape the container and mount the host filesystem, gaining root privileges on the host machine.

Evidence:

- `id` command revealed `docker` group membership.
- Used `docker run -v /:/mnt --rm -it bash chroot /mnt sh` to mount the host filesystem and access `/root/.ssh/id_rsa`.

Affected Assets:

- Host system (full compromise)

Remediation:

- Remove users from the `docker` group unless absolutely necessary.
- Restrict Docker access to authorized administrators only.
- Use `sudo` with strict controls instead of group membership.

6. Risk Summary

Finding	Severity
Information disclosure via web directory	Medium
Weak password policy (MD5 hashes)	High
Docker group misconfiguration (privilege escalation)	Critical

7. Tools Used

- Nmap (Network scanning and service enumeration)
- Gobuster (Directory enumeration)
- Hashcat (Password cracking – MD5 mode 0)
- SSH (Remote access)
- Docker (Privilege escalation via container escape)
- GTF0Bins (Technique reference for Docker escape)

8. Recommendations

Immediate Actions

- Restrict access to sensitive directories (e.g., `/uploads`) on the web server.
- Remove MD5 password hashes from publicly accessible locations.
- Enforce strong password policies (minimum 12 characters, complexity).
- Remove user `r00t` from the `docker` group to prevent privilege escalation.

Long-Term Improvements

- Implement file integrity monitoring to detect unauthorized file changes.
- Conduct regular security assessments and penetration tests.
- Apply security hardening standards (CIS benchmarks) to the system.
- Use modern password hashing algorithms (bcrypt, Argon2).
- Monitor and audit Docker group membership and usage.

9. Conclusion

The penetration test on the UltraTech machine was successfully completed.

The tester gained unauthorized access to the target system and escalated privileges to root, demonstrating the impact of multiple security weaknesses.

Key vulnerabilities identified include:

- Information disclosure via web directories.
- Weak password policy (MD5 hashes).
- Misconfigured Docker group leading to full system compromise.

Implementing the recommendations above will significantly improve the security posture of the environment and prevent similar attack paths.

Prepared By:

Titanium00

Penetration Tester

16/06/2026